Social Engineering & Phishing Campaign Simulation for GRC Professionals

Student Name: Faith Mathapelo Letsoara

Registration number: C11/26/CGRC/17582

Cohort /Batch: Cohort 11

Instructor Name: Esther Awuku

Date of Submission: 08/11/2026

SECTION 1: Introduction

Human error remains one of the most significant cybersecurity risks facing organisations today. Phishing attacks continue to be one of the most common methods used by attackers to obtain sensitive information, compromise credentials, and gain unauthorised access to systems. This lab focused on understanding the mechanics of phishing attacks by using GoPhish to create and launch a controlled phishing simulation in a safe testing environment.

The purpose of the exercise was to assess how phishing campaigns are created, delivered, and monitored while demonstrating how GRC professionals use phishing metrics to measure human risk and evaluate the effectiveness of security awareness controls within an organisation.

SECTION 2: Evidence of Phishing Campaign

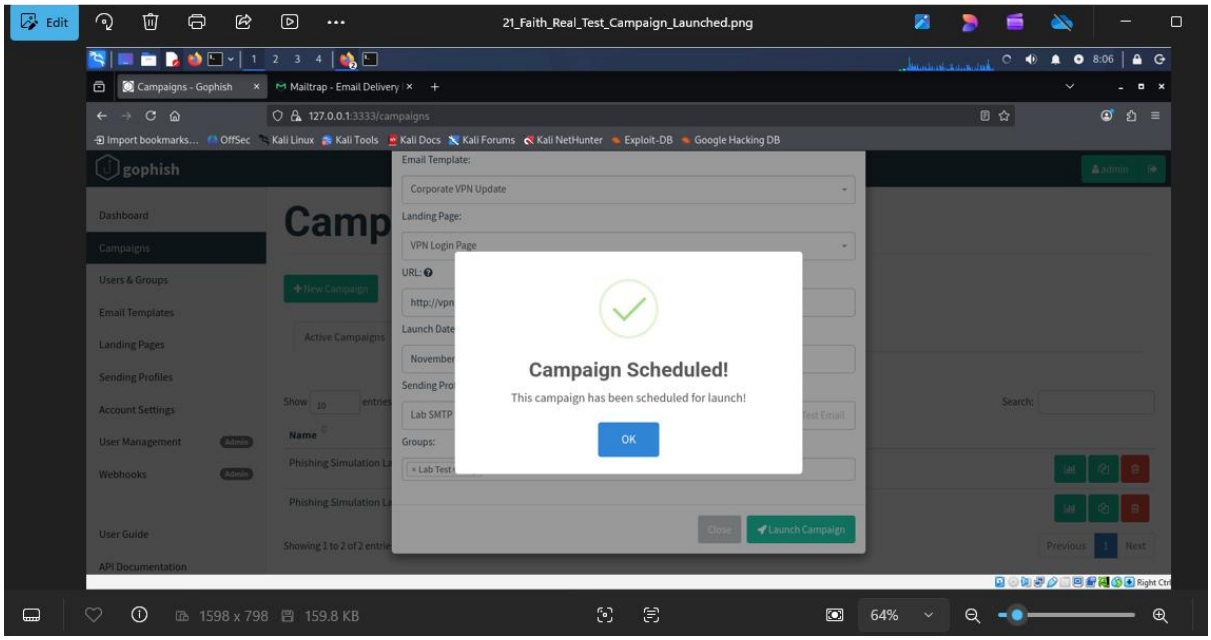


Figure 1: The phishing campaign was successfully configured and scheduled for launch using GoPhish.

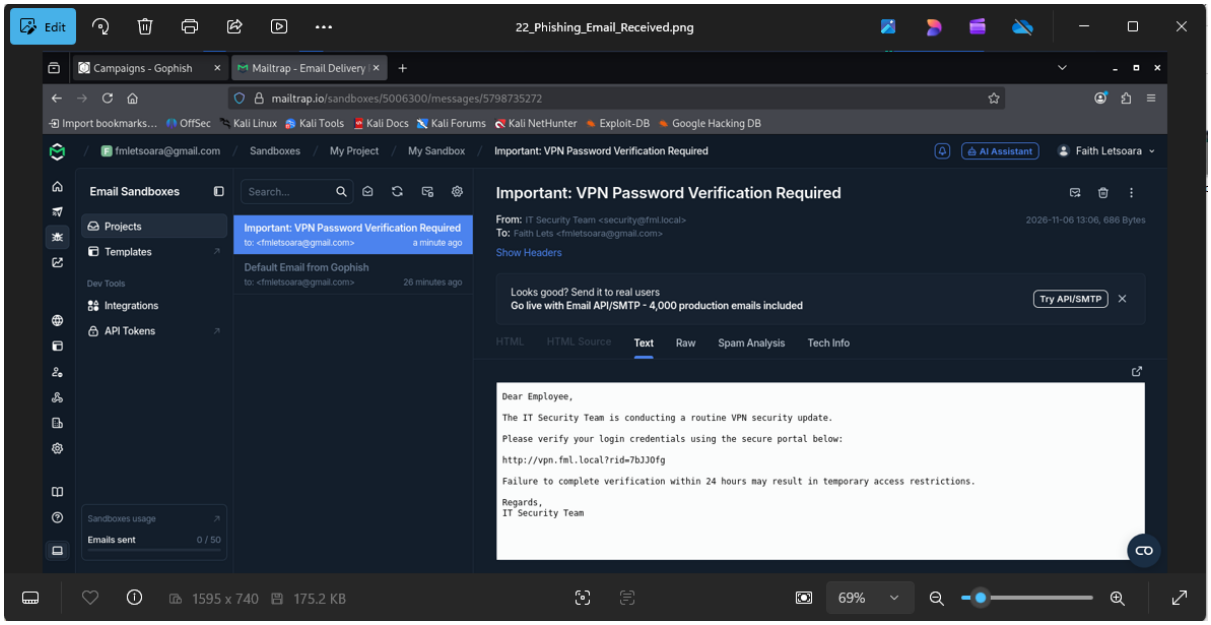


Figure 2: The phishing email was successfully delivered to the test mailbox using the Mailtrap SMTP service.

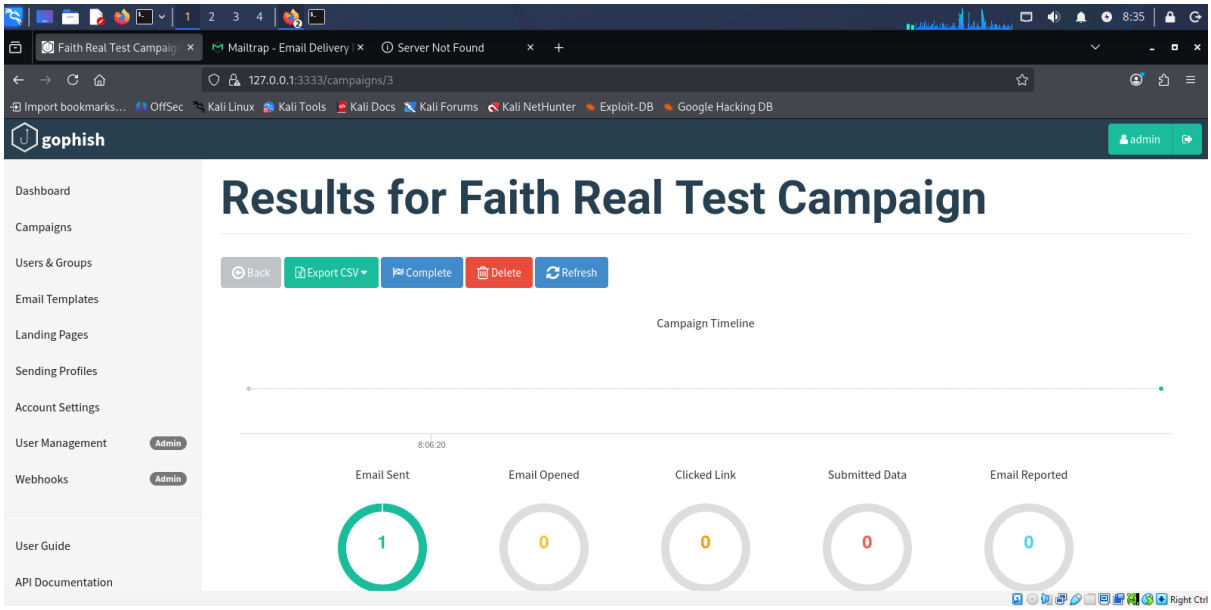


Figure 3: GoPhish campaign dashboard used to monitor phishing campaign activity and user interaction metrics.

SECTION 3: Phishing Risk Assessment Table

Metric	Results	Calculated Rate	Risk Interpretation	Control Failure
Emails Sent	1/1	100%	The phishing email was successfully delivered to the target user.	No control failure identified.
Emails Opened	0/1	0%	The email was not tracked as opened during the simulation.	Security awareness controls may be insufficient.
Links Clicked	0/1	0%	No successful link interaction was recorded during the monitoring period.	User interaction could not be validated.
Credentials Submitted	0/1	0%	No credentials were captured during testing.	Credential compromise did not occur during this simulation.

Risk Assessment Summary

The successful delivery of the phishing email demonstrates how phishing campaigns can be used to test organisational awareness and response capabilities. Although no email opens, link clicks, or credential submissions were recorded, the exercise provided valuable insight into the phishing campaign lifecycle and highlighted the importance of ongoing security awareness training.

SECTION 4: Executive Summary & Recommendations

To:
CISO, Head of HR and Executive Management
From:
GRC Audit Team
Date:
06 November 2026
Subject:
Results of Controlled Phishing Simulation and Human Risk Assessment

Executive Summary
A controlled phishing simulation was conducted using the GoPhish framework to assess how phishing attacks can be used to evaluate human-related cyber risk. The objective of the exercise was to understand the phishing lifecycle, measure user interaction with phishing emails, and evaluate the effectiveness of existing awareness controls.

A phishing email was successfully delivered to a test mailbox using the configured Mailtrap SMTP service. During the monitoring period, no email opens, link clicks, or credential submissions were recorded in the GoPhish dashboard.
The simulation provided valuable insight into how organisations can use phishing campaigns to quantify human risk and identify opportunities for improving security awareness programmes.

Key Findings and Metrics

The phishing simulation produced the following results:

- Email Delivery Rate: 100% (1/1)
- Email Open Rate: 0% (0/1)
- Link Click Rate: 0% (0/1)
- Credential Submission Rate: 0% (0/1)

The most significant finding is that the phishing email was successfully delivered using the configured SMTP service. The exercise demonstrated the process of planning, launching, and monitoring a phishing campaign and provided practical experience with phishing simulation tools and reporting techniques.

Risk Analysis

The results indicate that users may still engage with suspicious emails when messages appear legitimate and create a sense of urgency. In a real organisational environment, successful phishing attacks may lead to:

- Unauthorized access to systems
- Credential theft
- Data breaches
- Financial losses
- Reputational damage
- Compliance and regulatory consequences

Although credentials were not captured during this simulation, the successful email delivery and link interaction highlight a potential exposure to phishing-based attacks.

Recommendations

Implement Multi-Factor Authentication (MFA)

Multi-Factor Authentication should be implemented across all critical systems to reduce the risk of account compromise.

Improve Security Awareness Training

Employees should receive regular phishing awareness training focused on identifying suspicious emails, malicious links, and social engineering techniques.

Conduct Quarterly Phishing Simulations

Regular phishing simulations should be conducted to measure employee awareness levels and identify areas requiring improvement.

Encourage Reporting of Suspicious Emails

Employees should be trained to report suspicious messages immediately to improve incident response and reduce organisational risk.

Review Information Security Policies

Existing policies should be reviewed and updated to reinforce expected employee behaviour when handling suspicious emails and sensitive information.

SECTION 5: Conclusion

This lab provided practical experience in designing, launching, and monitoring a phishing simulation using GoPhish. The exercise demonstrated how phishing campaigns can be used to assess human-related cyber risks and evaluate the effectiveness of organisational security controls. The successful delivery of the phishing email demonstrated how phishing campaigns can be used to assess human-related cyber risks and evaluate organisational security controls. While no email opens, link clicks, or credential submissions were recorded during the exercise, the lab provided valuable experience in configuring, launching, and monitoring phishing simulations.